

Setup Laboratorio Virtuale, Analisi Malware e Identificazione IOC

Corso	Cybersecurity & Ethical Hacking
Studiante	Lorenzo Ventanni
Ambiente	FlareVM su Oracle VirtualBox
Data	01/06/2026
Obiettivo	Configurazione lab, analisi malware e identificazione IOC tramite VirusTotal

1. Introduzione

In questo laboratorio ho configurato un ambiente FlareVM dedicato all'analisi statica di campioni malware e ho eseguito una serie di operazioni pratiche per la raccolta di Indicatori di Compromissione (IOC). L'esercitazione prevedeva la creazione di uno snapshot pulito della macchina virtuale, la simulazione di una chiave di persistenza nel registro di Windows, la scompattazione di campioni malware e il calcolo dei relativi hash, seguito da una ricerca su VirusTotal per l'identificazione degli IOC.

I tre campioni analizzati appartengono a famiglie malware ben documentate: BadRabbit (ransomware), butterflyondesktop.exe (loader/bundler) e frankenstein.doc (downloader/stager della Frankenstein Campaign documentata da Cisco Talos nel 2019).

2. Obiettivi

- Creare uno snapshot "Clean" della VM FlareVM come punto di ripristino pre-analisi.
- Simulare la creazione di una chiave di persistenza manuale in HKCU\...\Run tramite regedit e verificarne l'effetto al riavvio.
- Scompattare i campioni malware scaricati tramite lo script malwareRepo.ps1 nella cartella Malware del Desktop.
- Calcolare gli hash MD5 e SHA-256 dei campioni tramite HashMyFiles.
- Ricercare i 3 hash su VirusTotal e analizzare i tab Detection, Behavior e Relations.
- Compilare una tabella IOC con hash, domini C2 e chiavi di registro identificate.

3. Ambiente e Strumenti

L'analisi e' stata condotta interamente su macchina virtuale per isolare il sistema host da qualsiasi rischio di contaminazione.

Componente	Dettaglio
Hypervisor	Oracle VirtualBox
VM di analisi	FlareVM (Windows 10) - snapshot CLEAN2 del 01/06/2026
Tool di hashing	HashMyFiles
Threat Intelligence	VirusTotal
Analisi IOC	Tab Detection, Behavior, Relations su VirusTotal
Script lab	malwareRepo.ps1 (Desktop FlareVM)

4. Procedura

STEP 1 Creazione dello snapshot "Clean" della VM

Prima di avviare qualsiasi operazione con campioni malware ho creato uno snapshot della FlareVM in uno stato pulito. Dal Gestore VirtualBox ho selezionato la VM FlareVM, aperto il pannello Istantanee e creato una nuova istantanea denominata CLEAN2. Questo permette di ripristinare rapidamente l'ambiente in caso di compromissione accidentale del sistema di analisi.

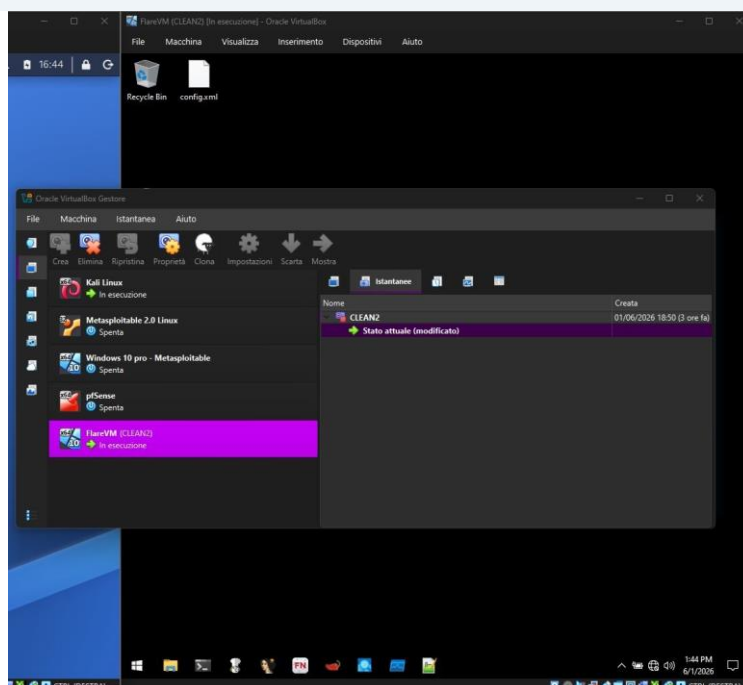


Fig. 1 — Snapshot "CLEAN2" creato il 01/06/2026 alle 18:50 nel Gestore Istantanee di VirtualBox. La voce "Stato attuale (modificato)" indica che la VM e' operativa a partire da quel punto di ripristino.

Risultato: ✓ Snapshot CLEAN2 creato correttamente. La VM e' ripristinabile allo stato pulito in qualsiasi momento.

STEP 2**Simulazione chiave di persistenza in HKCU\Run**

Ho aperto regedit e navigato al percorso

HKEY_CURRENT_USER\SOFTWARE\Microsoft\Windows\CurrentVersion\Run. Ho creato un nuovo valore stringa denominato "Persistent KEY" con il dato C:\Windows\System32\calc.exe. Questo simula il meccanismo di autorun utilizzato da numerosi malware per garantire la persistenza al riavvio del sistema, in modo del tutto analogo a quanto osservato nel campione butterflyondesktop.exe.

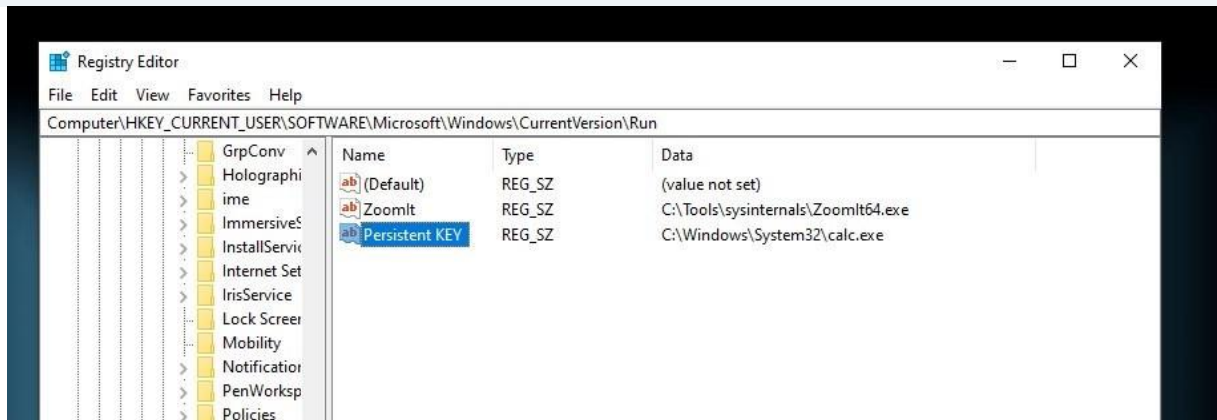


Fig. 2 — Chiave "Persistent KEY" creata in HKCU...\CurrentVersion\Run con valore C:\Windows\System32\calc.exe.

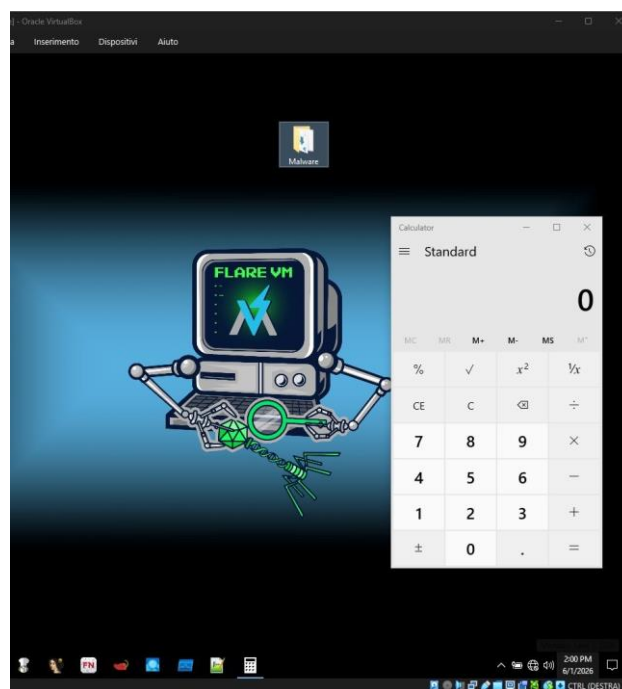


Fig. 3 — Verifica al riavvio: la Calcolatrice di Windows si avvia automaticamente, confermando che la chiave di registro viene letta e il processo eseguito al login utente. Sul desktop e' visibile anche la cartella Malware creata dallo script malwareRepo.ps1.

Risultato: ✓ La chiave di persistenza funziona correttamente: calc.exe si avvia automaticamente al riavvio, simulando il comportamento di un malware con autorun.

STEP 3**Esecuzione script malwareRepo.ps1 e cartella Malware**

Ho eseguito lo script malwareRepo.ps1 presente sul Desktop della FlareVM in PowerShell con privilegi di amministratore. Lo script ha scaricato e organizzato i campioni malware nella cartella C:\Users\FlareVm\Desktop\Malware, suddivisi per categoria in sottocartelle (Banking-Malware, Botnets, Browser Hijackers, Ransomware, RAT, Stealer, Trojan, ecc.).

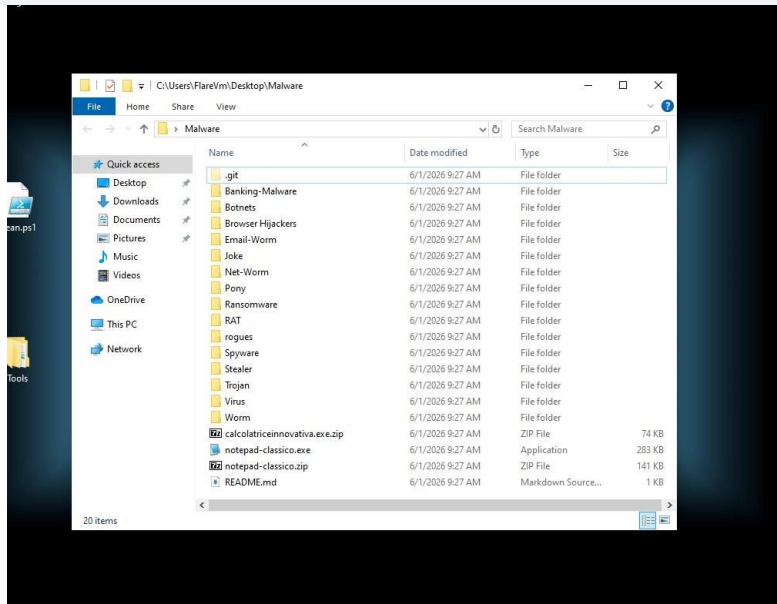


Fig. 4 — Contenuto della cartella Malware sul Desktop della FlareVM dopo l'esecuzione dello script. Sono visibili 17 sottocartelle per categoria e 3 file aggiuntivi: calcolatriceinnovativa.exe.zip, notepad-classico.exe e notepad-classico.zip.

Risultato: ✓ Script eseguito correttamente. La cartella Malware è popolata con campioni suddivisi per categoria.

STEP 4**Scompattazione dei campioni e preparazione per l'analisi**

Ho estratto gli archivi contenenti i tre campioni selezionati per questa esercitazione. I file sono stati scompattati direttamente sul Desktop della FlareVM, mantenendo la VM isolata dalla rete host durante tutta l'operazione.

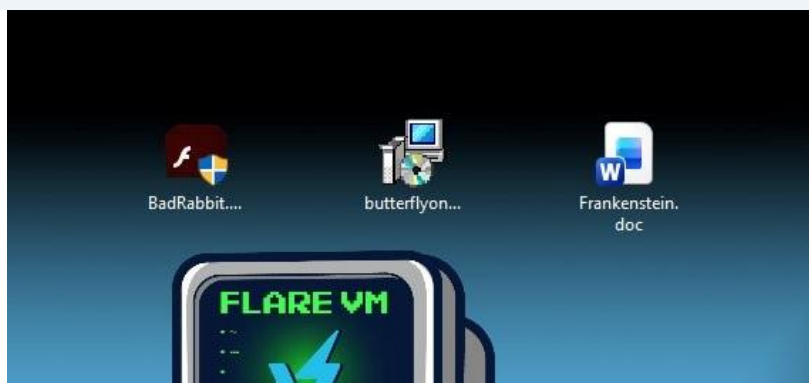
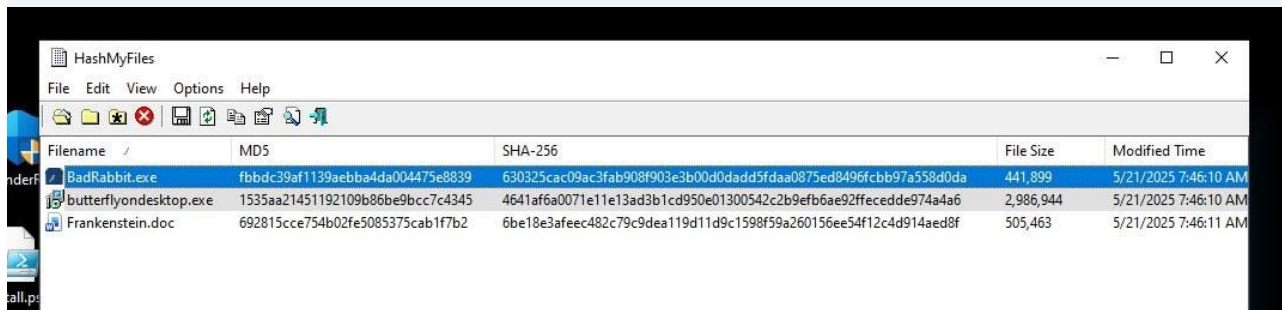


Fig. 5 — I tre campioni scompattati sul Desktop della FlareVM: BadRabbit.exe (ransomware), butterflyondesktop.exe (loader/bundler) e Frankenstein.doc (downloader/stager).

Risultato: ✓ I tre campioni sono disponibili sul Desktop e pronti per il calcolo degli hash.

STEP 5**Calcolo degli hash con HashMyFiles**

Ho utilizzato HashMyFiles (NirSoft) per calcolare gli hash MD5 e SHA-256 dei tre campioni. I valori ottenuti sono stati poi utilizzati per la ricerca su VirusTotal e per la compilazione della tabella IOC. Il calcolo degli hash e' fondamentale perche' consente di identificare univocamente un campione malware anche in assenza del file originale.



Filename	MD5	SHA-256	File Size	Modified Time
BadRabbit.exe	fbdbc39af1139aebba4da004475e8839	630325cac09ac3fab908f903e3b00d0dadd5fdaa0875ed8496fcbb97a558d0da	441,899	5/21/2025 7:46:10 AM
butterflyondesktop.exe	1535aa21451192109b86be9bcc7c4345	4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92ffecedde974a4a6	2,986,944	5/21/2025 7:46:10 AM
Frankenstein.doc	692815cce754b02fe5085375cab1f7b2	6be18e3afeec482c79c9dea119d11d9c1598f59a260156ee54f12c4d914aed8f	505,463	5/21/2025 7:46:11 AM

Fig. 6 — Output di HashMyFiles con MD5 e SHA-256 per i tre campioni: BadRabbit.exe, butterflyondesktop.exe e Frankenstein.doc. I valori corrispondono a quelli attesi dalla ricerca su VirusTotal, confermando l'autenticita' dei campioni.

Risultato ✓ Hash calcolati e verificati: i valori SHA-256 corrispondono esattamente a quelli presenti nei report VirusTotal e nelle fonti Cisco Talos/Qualys

5. Tabella IOC

Dopo aver ricercato i tre hash su VirusTotal e analizzato i tab Detection, Behavior e Relations, ho compilato la seguente tabella degli Indicatori di Compromissione per ciascun campione.

I. BadRabbit · Ransomware · install_flash_player.exe

Tipo IOC	Valore
SHA256	630325cac09ac3fab908f903e3b00d0dadd5fdaa0875ed8496fcbb97a558d0da
MD5	FBBDC39AF1139AEBBA4DA004475E8839
SHA1	DE5C8D858E6E41DA715DCA1C019DF0BFB92D32C0
SHA256	8ebc97e05c8e1073bda2efb6f4d00ad7e789260afa2c276f0c72740b838a0a93 (dispcli.exe)
SHA256	579fd8a0385482fb4c789561a30b09f25671e86422f40ef5cca2036b28f99648 (csccl.dat)
C2 Domain	1dnscontrol[.]com
C2 IP	185.149.120[.]3
File dropped	%windir%\infpub.dat %windir%\dispcli.exe %windir%\csccl.dat
Sched. Task	rhaegal.job - esegue decryptor

Tipo IOC	Valore
	drogon.job - shutdown viserion_23.job - riawvio
CVE	CVE-2017-0145 - EternalRomance / SMB
Registry Key	N/D - persistenza via Scheduled Task

II. ButterflyOnDesktop · Loader / Bundler · butterflyondesktop.exe

Tipo IOC	Valore
SHA256	4641af6a0071e11e13ad3b1cd950e01300542c2b9efb6ae92ffecedde974a4a6
MD5	1535AA21451192109B86BE9BCC7C4345
SHA1	1AF211C686C4D4BF0239ED6620358A19691CF88C
SHA256	78fe70328471cc2149ef0df79215f10cb53c4d32dd4193f39c50abbd9eab2eef (variante stealer)
C2 Domain	cn.freedesktopsoft.com
Ad Network ID	ca-pub-0235095201432841 (Google AdSense)
File dropped	Butterfly on Desktop.lnk Uninstall Butterfly on Desktop.lnk livecamwallpaper.tmp / freeclock.tmp LivecamWallpaper.exe / FreeDesktopClock.exe
Registry Key	HKCU\Software\Microsoft\Windows\CurrentVersion\Run (Sigma: CurrentVersion Autorun Keys Modification)
Parent dropper	Spyware.zip (56/67) · UnpackerWindowless.exe (50/70)
AS contattati	AS15169 (Google) · AS20940 (Akamai)

III. Frankenstein · Downloader / Stager · frankenstein.doc

Tipo IOC	Valore
SHA256	6be18e3afeec482c79c9dea119d11d9c1598f59a260156ee54f12c4d914aed8f
C2 Domain	droobox[.]online
C2 URL	hxxp://droobox[.]online:80/luncher.doc
File dropped	luncher.doc (2° stage) %LOCALAPPDATA%\Intel\instal.xml
Sched. Task	WinUpdate - DAILY @ 09:00 (PowerShell base64 stager)
Registry Key	N/D - persistenza via Scheduled Task WinUpdate
CVE	CVE-2017-11882 - MS Office Equation Editor
Tool usati	PowerShell Empire · FruityC2 · MSBuild
Dati esfiltrati	Username · IP pubblico · processi · OS version · privilegi → Cifratura AES-CBC
Anti-analisi	VMware / VBox detection · Process Explorer / Wireshark / Fiddler · Check core CPU < 2

6. Risultati

L'esercitazione ha prodotto i risultati attesi in tutte le fasi previste dalla traccia. Lo snapshot CLEAN2 e' stato creato correttamente e garantisce un punto di ripristino affidabile. La simulazione della chiave di persistenza ha dimostrato concretamente come un malware possa sopravvivere al riavvio tramite la chiave CurrentVersion\Run, con calc.exe avviata automaticamente al login successivo.

L'analisi dei tre campioni su VirusTotal ha permesso di raccogliere IOC di qualita' diversa: BadRabbit presenta l'infrastruttura C2 piu' documentata (IP e dominio noti), frankenstein.doc mostra una catena di attacco complessa con strumenti open-source assemblati, mentre butterflyondesktop.exe e' il campione con il maggior numero di file dropped (637 secondo VT Relations) e l'unico con modifica diretta al registro.

7. Conclusioni

Il confronto tra i tre campioni ha evidenziato differenze significative nelle tecniche di persistenza e nei meccanismi di C2: BadRabbit usa Scheduled Task con nomi di fantasia ispirati a Game of Thrones, butterflyondesktop.exe sfrutta la chiave Run del registro, e frankenstein.doc costruisce uno stager PowerShell codificato in base64. Questo scenario multi-campione ha rappresentato un esercizio realistico di triage malware, avvicinandosi alle attivita' che un analista SOC svolge quotidianamente.